DELOITTE CYBER ENGINEERING - ROUND 2

SIEM Incident Investigation Intelligence

Complete project, architecture, code-flow and interview handbook

Prepared by Sahaj Bhadja

Meridian Health Partners | INC-2026-0610-001 | Interview edition | 30 July 2026

242	12	14	2
SIEM events	Findings	ATT&CK; techniques	Internal pivots

Purpose

Use this handbook to understand every project component, explain the complete evidence flow in a natural way, prepare the live UI demonstration, and answer detailed interview questions without memorizing code line by line.

Contents

1. Executive overview 5

The real operational problem . . . 5
The solution in one sentence . . . 5
What was reconstructed . . . 5
Core design thesis . . . 5

2. Assignment interpretation and requirements 6

Requirement-to-implementation mapping . . . 6
What is deliberately not claimed . . . 6

3. System architecture 7

Runtime flow . . . 7
Architecture boundaries . . . 8

4. Input data and normalization 9

Input profile . . . 9
Field alias strategy . . . 9
Before and after: EVT-0228 . . . 9

5. Core data model and Incident IR 10

Event . . . 10
EventStore . . . 10
Finding . . . 10
Incident . . . 10

6. End-to-end pipeline execution 11

1. Ingest . . . 11
2. Detect . . . 11
3. Correlate . . . 11
4. Validate . . . 11
5. Enrich . . . 11
6. Assess . . . 11
7. Package . . . 11
Actual execution result . . . 11

7. Detection catalogue 12

How C2 regularity is measured . . . 12
Why one suspicious event is not always enough . . . 12

8. Correlation, timeline and confidence 13

F-007 correlation proof . . . 13
Confidence vocabulary . . . 13
Timeline reconstruction . . . 13
Directional path . . . 13

9. MITRE ATT&CK; enrichment 14

Example mapping . . . 14
Why the catalogue is local . . . 14

10. Blast radius and uncertainty 15

Entity aggregation . . . 15
Strongest-confidence roll-up . . . 15
Coverage gaps are part of scope . . . 15

11. Synthesis, UI and optional GenAI 16

Deterministic synthesis builders . . . 16
Bounded question answering . . . 16
Optional model boundary . . . 16
UI API flow . . . 16

12. Trust, hallucination and security controls 17

Remaining failure modes . . . 17

13. Complete file-by-file reference 18

schema.py . . . 19
ingest.py . . . 19
model.py . . . 19
detectors.py . . . 19
correlate.py . . . 19
attack.py . . . 19
blast_radius.py . . . 19
synthesize.py . . . 19
llm.py . . . 20
report.py . . . 20
pipeline.py . . . 20
cli.py . . . 20
web.py . . . 20
UI files . . . 20

14. Verification and quality strategy 21

Current validation result . . . 21
Key invariants . . . 21
What should be added in production . . . 21

15. Running and presenting the project 22

Commands . . . 22
Eight-minute walkthrough . . . 22

16. Engineering tradeoffs and production roadmap 23

Deliberate scope cuts . . . 23
Another day . . . 23
Another week . . . 23
Production controls . . . 23

17. Comprehensive interview question bank 24

A. Problem, value and project framing . . . 24
B. Architecture and agentic design . . . 24
C. Data, schemas and normalization . . . 25
D. Detection and incident-specific evidence . . . 26
E. Correlation, confidence, ATT&CK; and blast radius . . . 28
F. UI, question answering and GenAI . . . 29
G. Trust, testing and engineering judgment . . . 30
H. Product and production thinking . . . 32
I. Live demonstration questions . . . 32

18. Final quick reference 34

Numbers to remember . . . 34
Evidence to remember . . . 34
Language to use . . . 34

1. Executive overview

The project is an evidence-first investigation accelerator. It turns fragmented logs into a defensible timeline, scope assessment and response brief while keeping every claim connected to the event that supports it.

The real operational problem

Security teams already possess large volumes of telemetry. Their problem is that endpoint, identity, firewall and cloud records describe different fragments of the same intrusion. A senior analyst must manually pivot between tools, align timestamps, resolve hosts and accounts, judge confidence and prepare separate technical and executive explanations.

- Raw search results are not an incident narrative.
- A missed cross-source relationship can hide lateral movement.
- Unsupported certainty can misdirect containment, legal review and breach reporting.
- The same investigation must serve analysts, responders, incident commanders and executives.

The solution in one sentence

Normalize the evidence once, detect behavior deterministically, correlate across sources, attach confidence and ATT&CK; context, package the result into one Incident IR, and let every UI or narrative view read from that same record.

What was reconstructed

Stage	Observed behavior	Evidence
Initial access	Word spawned cmd.exe, followed by encoded PowerShell on WKSTN-07	EVT-0221, EVT-0222
Command and control	Near-periodic HTTPS callbacks to 185.220.101.45	EVT-0223 to EVT-0225
Credential access	PowerShell accessed LSASS and a dump-like temporary file appeared	EVT-0226, EVT-0227
First pivot	jdavis authenticated from WKSTN-07 to AUTH-SRV-01	EVT-0228
Second pivot	SMB to FILE-SRV-02, PSEXESVC creation and SYSTEM shell	EVT-0231 to EVT-0233
Collection	Finance data compressed into a 2.3 GiB archive	EVT-0236, EVT-0237
Exfiltration	Archive uploaded to externally owned ext-drop-xf9q2	EVT-0238
Cleanup	Archive, tool and PSEXESVC deleted	EVT-0239 to EVT-0241

Core design thesis

- Agentic structure: the task is decomposed into bounded investigation stages.
- Deterministic substance: parsing, detection, evidence, confidence and correlation are reproducible code.
- Optional GenAI: a model may classify intent or narrate established facts, but it cannot create findings.
- Human control: response actions are recommendations, never autonomous containment.

2. Assignment interpretation and requirements

The strongest answer to the brief is not a general chatbot. It is a tangible investigation workflow that demonstrates multi-source reasoning, ATT&CK; context, traceability, uncertainty and communication.

Requirement-to-implementation mapping

Brief requirement	Implementation	Proof in demo
Multi-source correlation	EventStore entity resolution plus time/entity correlation in detectors	F-007 joins network and endpoint evidence
Timeline reconstruction	Chronological Finding timestamps and stable F-### IDs	12-stage UI timeline
ATT&CK; mapping	Curated local technique catalogue with optional live reconciliation	14 techniques across 9 tactics
Blast radius	Aggregation of finding hosts, accounts and cloud resources	3 hosts, 1 account, 1 external bucket
Traceability	Every Finding stores evidence event IDs; original records are preserved	Clickable evidence drawer
Agentic workflow	Ingest -> normalize -> detect -> correlate -> enrich -> assess -> synthesize	Live Run investigation flow
Questions	Bounded deterministic intent builders over the Incident IR	Ask investigation view
Trust discussion	Confidence states, citation checks, coverage gaps and human approval gate	Trust rail and gap panels

What is deliberately not claimed

- The phishing email itself is not directly observed because email telemetry is absent.
- AUTH-SRV-01 is treated as an authentication server and pivot, not automatically called a domain controller.
- No PHI claim is made; the observed archive contains finance data.
- No access-key rotation is claimed because the log does not contain an access-key ID.
- No finding is not treated as proof that a system is clean.

3. System architecture

The forensic engine is intentionally separated from presentation. The browser executes the real pipeline, receives a structured Incident payload and retrieves source evidence on demand.

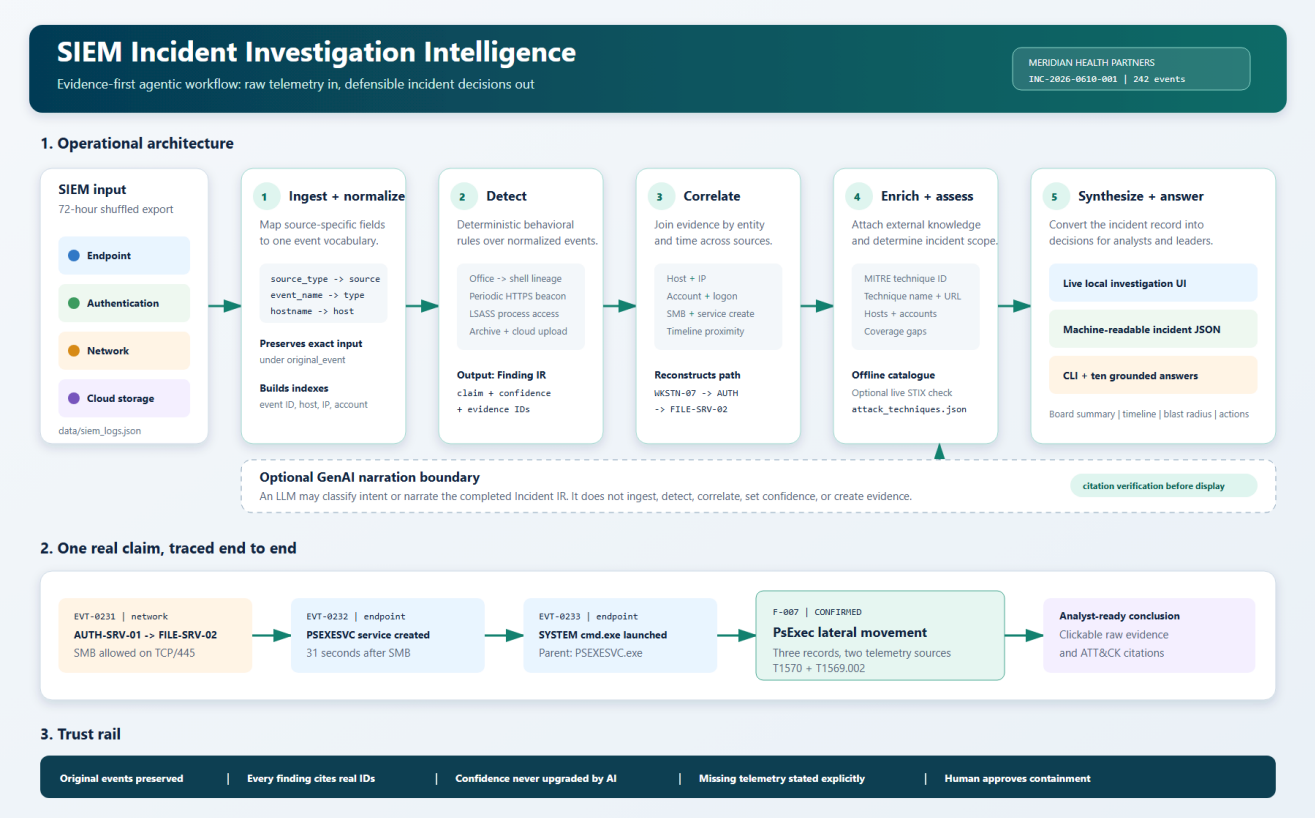


Figure 1. Operational pipeline, real F-007 evidence trace and trust boundary.

Runtime flow

```
Browser: Run investigation
  -> POST /api/investigate
  -> web.InvestigationHandler._run_investigation()
  -> pipeline.run(data/siem_logs.json)
     -> ingest.load()
     -> detectors.run_all()
     -> correlate.assign_ids_and_order()
     -> attack.load_catalogue()
     -> blast_radius.*()
     -> Incident
  -> web._incident_payload()
  -> UI overview, timeline, ATT&CK, scope, gaps, actions and Q&A
```

Architecture boundaries

Boundary	Owns	Does not own
Data adapter	Field aliases, metadata aliases, source preservation	Maliciousness or confidence
Detection	Behavioral rules and evidence selection	Executive wording
Correlation	Entity/time relationships, path and ordering	ATT&CK; names
Enrichment	Technique names, tactics and URLs	Compromise decisions
Synthesis	Audience-specific views over the Incident IR	New forensic facts
UI	Interaction and presentation	Detection, correlation or confidence
Optional LLM	Intent classification and narration	Findings, evidence or response execution

4. Input data and normalization

Normalization makes different source schemas comparable without rewriting or discarding the original evidence. It is an adapter layer, not a detector.

Input profile

Property	Value
Organisation	Meridian Health Partners (synthetic)
Incident reference	INC-2026-0610-001
Window	2026-06-10 08:00 UTC to 2026-06-13 08:00 UTC
Events	242 shuffled records
Sources	endpoint 65, auth 62, network 84, cloud_storage 31

Field alias strategy

Supplied field	Canonical field	Reason
source_type	source	One source discriminator for all Event objects
event_name	event_type	One behavioral event vocabulary
username	user / principal	Shared account access
hostname or dest_host	host	Host property with source-aware meaning
source_ip	src_ip	Consistent network/auth/cloud source address
process_name	process	Consistent process detector input
file_size_bytes	file_size	Consistent size calculations
file_upload	PutObject	Canonical cloud object operation
bucket_owner=EXTERNAL	dst_external=true	Explicit destination trust boundary

Before and after: EVT-0228

```
ORIGINAL AUTH RECORD
event_name:  user_logon
username:    jdavis
source_host: WKSTN-07
dest_host:   AUTH-SRV-01
logon_type:  network
source_ip:   10.0.2.47

NORMALIZED VIEW
event_type:  logon_success
user:        jdavis
src_host:    WKSTN-07
host:        AUTH-SRV-01
logon_type:  3
src_ip:      10.0.2.47
```

The full original JSON object remains available under **original_event**. In the UI, the analyst can switch between Original event and Normalized view, making the transformation visible and auditable.

5. Core data model and Incident IR

> *The structured intermediate representation is the contract between the forensic pipeline and every presentation surface.*

Event

- Immutable normalized wrapper around one source record.
- Carries event ID, source, UTC datetime and the complete normalized/raw dictionary.
- Provides host, user, timestamp and citation convenience accessors.

EventStore

- Chronologically sorts all events and indexes them by event ID.
- Groups events by source and resolves observed host/IP pairs.
- Allows detectors to connect an IP in a firewall row with a hostname in endpoint telemetry.

Finding

```
Finding(
  id="F-007",
  title="Lateral movement to FILE-SRV-02 via PsExec",
  phase="Lateral Movement",
  technique_ids=["T1570", "T1569.002"],
  severity="critical",
  confidence="CONFIRMED",
  evidence=["EVT-0231", "EVT-0232", "EVT-0233"],
  hosts=["AUTH-SRV-01", "FILE-SRV-02"],
  accounts=["jdavis"]
)
```

Incident

- Ordered findings and complete timeline.
- Host, account and cloud blast-radius records.
- Coverage gaps, ATT&CK; catalogue, statistics and attack path.
- Reference to the EventStore for source evidence.
- Serializable representation used by investigation.json and the UI API.

6. End-to-end pipeline execution

> *pipeline.run() is the single investigation entry point. Every consumer receives the same Incident result, preventing the CLI, UI and reports from drifting into conflicting cases.*

1. Ingest

Load JSON, normalize metadata and event fields, parse UTC timestamps, skip malformed rows and create EventStore.

2. Detect

Run all deterministic detectors and capture reviewed benign near-misses.

3. Correlate

Order findings, assign F-### IDs, calculate statistics and build directional edges.

4. Validate

Emit loud schema/source/entity warnings and refuse to treat an empty result as proof of safety.

5. Enrich

Load local ATT&CK; names, tactics and URLs; optionally compare with the live STIX feed.

6. Assess

Aggregate host, account and cloud scope and derive coverage gaps.

7. Package

Return Incident with timeline, path, ATT&CK; matrix, evidence, scope and gaps.

Actual execution result

```
events:       242 across 4 sources
findings:     12 confirmed
ATT&CK:       14 techniques across 9 tactics
attack path:  WKSTN-07 -> AUTH-SRV-01 -> FILE-SRV-02
blast radius: 3 hosts, 1 account, 1 external bucket
duration:     11.9 hours
```

7. Detection catalogue

Detectors are deterministic behavior rules. They do not read the dataset's ATTACK validation notes and they always attach the event IDs that justify their conclusion.

Detector	Behavior	Main conditions	Current evidence
Initial access	Office-to-shell execution	process_create; Office parent; script/command child	EVT-0221
Encoded PowerShell	Obfuscated script execution	PowerShell process plus encoded/stealth flags	EVT-0222
C2 beaconing	Automated web callbacks	Internal-to-external flows; 3+ events; low interval variation	EVT-0223-0225
Persistence	Scheduled task or run-key	schtasks /create or equivalent run-key behavior	Not present in Meridian path
Discovery	Account/system reconnaissance	Multiple known discovery commands on one host	EVT-0229, 0230
LSASS access	Credential dumping	Known dump command or process_access targeting lsass.exe	EVT-0226, 0227
Valid-account pivot	Stolen credential use	LSASS access followed by network logon from same source/account	EVT-0226, 0228
Lateral movement	Remote service execution	SMB plus PSEXESVC service/shell in time window	EVT-0231-0233
Domain-admin abuse	Suspicious DC logon	Target is known DC plus privilege/off-hours/server-source context	Not asserted here
Data staging	Archive creation	Known archiver process plus nearby file write	EVT-0236, 0237
Cloud mass access	Bulk sensitive reads	Repeated reads from sensitive bucket and external source	Not needed here
Cloud exfiltration	External object upload	Put/Copy object to explicit/non-owned destination	EVT-0238
Defense evasion	Cleanup/indicator removal	Security disable, log clear, file/service deletion	EVT-0239-0241

How C2 regularity is measured

Flows are grouped by internal source IP and external destination IP. Consecutive time deltas are calculated, then the coefficient of variation is used to reject irregular human browsing. The three Meridian callbacks are approximately 15.5 minutes apart with very low jitter.

Why one suspicious event is not always enough

A single SMB connection can be routine administration. A single PowerShell launch can be legitimate. The detector either requires a particularly direct audit fact or corroboration such as process lineage, temporal proximity, repeated intervals or multiple source types.

8. Correlation, timeline and confidence

Correlation connects different records that describe consecutive parts of one behavior. It uses entities and time; it is not a simple same-versus-different comparison.

F-007 correlation proof

Time	Source	Event	Meaning
13:11:33	Network	EVT-0231	AUTH-SRV-01 connects to FILE-SRV-02 over allowed SMB/445
13:12:04	Endpoint	EVT-0232	FILE-SRV-02 creates PSEXESVC 31 seconds later
13:12:07	Endpoint	EVT-0233	PSEXESVC.exe launches cmd.exe with SYSTEM integrity

Together, these events support a critical CONFIRMED lateral-movement finding. Network and endpoint telemetry independently describe the transfer, remote service and resulting shell.

Confidence vocabulary

State	Meaning	Example
CONFIRMED	Multi-source corroboration or one direct, unambiguous audit record	PsExec chain; external upload
SUSPECTED	Meaningful signal without enough independent support	Encoded PowerShell without supporting activity
UNCERTAIN	Access/indirect evidence exists but missing telemetry prevents a conclusion	Remote logon to a host with no EDR

Timeline reconstruction

Findings carry representative timestamps. They are sorted chronologically and assigned stable F-### identifiers. The first malicious finding is 08:12:33 UTC, the last is 20:05:38 UTC, producing an observed duration of 11.9 hours.

Directional path

```
F-005  WKSTN-07   -> AUTH-SRV-01  via valid account
F-007  AUTH-SRV-01 -> FILE-SRV-02  via SMB/PsExec
```

9. MITRE ATT&CK; enrichment

> *ATT&CK; gives standardized language for behavior already established by evidence. It enriches a finding; it does not decide whether compromise occurred.*

Example mapping

Finding behavior	Technique	Name
Malicious attachment lineage	T1566.001	Phishing: Spearphishing Attachment
Encoded PowerShell	T1059.001	Command and Scripting Interpreter: PowerShell
LSASS access	T1003.001	OS Credential Dumping: LSASS Memory
Valid-account pivot	T1078.002	Valid Accounts: Domain Accounts
PsExec transfer	T1570	Lateral Tool Transfer
PsExec service	T1569.002	System Services: Service Execution
Archive creation	T1560.001	Archive Collected Data: Archive via Utility
Cloud upload	T1567.002	Exfiltration to Cloud Storage
Cleanup	T1070.004	Indicator Removal: File Deletion

Why the catalogue is local

- The demo works without network access.
- Technique names and URLs are not generated by a model.
- Only implemented/relevant techniques are shipped.
- --refresh-attack can reconcile the subset with MITRE's live enterprise STIX feed.

10. Blast radius and uncertainty

Blast radius rolls finding-level entities into an incident-level scope. It answers which hosts, accounts and cloud resources require containment or further investigation.

Entity aggregation

Entity	Status	Role	Why included
WKSTN-07	CONFIRMED	Initial foothold	Execution, C2 and credential access findings
AUTH-SRV-01	CONFIRMED	First pivot	Remote account use and reconnaissance
FILE-SRV-02	CONFIRMED	Data source	PsExec, archive, upload and cleanup
jdavis	CONFIRMED	Abused account	Appears across initial context, pivots and exfiltration
ext-drop-xf9q2	CONFIRMED	External destination	Explicit EXTERNAL bucket owner in EVT-0238

Strongest-confidence roll-up

If several findings touch one entity, its summary status reflects the strongest supported finding: CONFIRMED over SUSPECTED over UNCERTAIN. This summarizes entity risk; it does not rewrite weaker findings.

Coverage gaps are part of scope

- No email logs: the delivery message cannot be examined.
- No DNS logs: the C2 IP cannot be resolved to the queried domain.
- No web-proxy logs: the URL path and other web activity cannot be inspected.
- Observed cleanup means absence of later artifacts must be interpreted carefully.

11. Synthesis, UI and optional GenAI

Synthesis creates audience-specific explanations from the Incident IR. The UI renders those views and retrieves evidence; it never performs forensic judgment itself.

Deterministic synthesis builders

Builder	Output
q_timeline	Full chronological walkthrough
q_initial_access	Entry vector and supporting process evidence
q_techniques	ATT&CK; technique list
q_accounts	Compromised or abused identities
q_hosts	Internal movement and attack path
q_exfil	Exfiltration evidence, content and time
q_blast_radius	Affected hosts, accounts and cloud resources
q_gaps	Visibility limits and impact
q_exec_summary	Three-sentence board briefing
q_ir_actions	Evidence-conditioned next-two-hour actions

Bounded question answering

The prototype routes questions to supported investigation intents. The answers are dynamically built from the current Incident; they are not static canned paragraphs. The current keyword router is intentionally constrained and some unusual paraphrases may fall back to suggestions.

Optional model boundary

- May classify a free-form query into one supported intent.
- May narrate the completed structured incident for an audience.
- Cannot create findings, choose evidence, assign confidence or execute actions.
- Any cited event/finding ID is checked against the valid Incident ID set.

UI API flow

```
GET  /api/info             dataset preflight only
POST /api/investigate      execute pipeline.run() and return Incident view
GET  /api/evidence/<id>    return normalized + original event
POST /api/ask              answer from current Incident IR
```

12. Trust, hallucination and security controls

The project treats unsupported certainty as a security defect. Trust comes from deterministic conclusions, evidence retention, explicit limits and human approval.

Control	Protection
Evidence invariant	Every finding cites at least one real event ID.
Original record	Normalization never removes the supplied source object.
Deterministic detectors	Same data and content version produce the same findings.
Confidence labels	Evidence strength is explicit rather than implied by prose.
Coverage gaps	Missing sources are part of the final conclusion.
Citation verification	Optional model output cannot silently cite phantom IDs.
Schema warnings	Missing/renamed fields fail loudly instead of yielding silent emptiness.
Local default	No API key or internet dependency for the forensic path.
Human approval	The system recommends but never performs containment.

Remaining failure modes

- A deterministic rule can still be incomplete or wrong.
- An attacker can operate in telemetry blind spots.
- Asset/IP resolution can become stale in production.
- Legitimate administration can resemble attacker behavior.
- ATT&CK; content can drift over time.
- A valid citation does not guarantee that model-written prose interpreted it correctly.
- Synthetic data is smaller and cleaner than real enterprise telemetry.

13. Complete file-by-file reference

Every repository file has a defined role. Generated artifacts are separated from source code, the authoritative dataset is singular, and tests cover each major trust boundary.

File	What it means and how it is used
.gitignore	Keeps caches, virtual environments, keys and local environment files out of Git.
README.md	Primary project documentation and timed interview presentation script.
CODE_WALKTHROUGH.md	Compact implementation and UI request-flow guide.
SIEM_PIPELINE_EXPLAINED.md	Detailed raw-log-to-UI tutorial with real event examples.
DT Cyber_Assignment 2_Incident_Investigation_Intelligence.pdf	Original assignment brief and evaluation criteria.
requirements.txt	Optional Anthropic, requests and pytest dependencies. Core runtime remains standard-library only.
data/siem_logs.json	Authoritative 242-event Meridian dataset used by default.
data/attack_techniques.json	Curated offline ATT&CK; subset: IDs, names, tactics, URLs and summaries.
docs/architecture.svg	Presentation-ready editable architecture image.
docs/architecture.html	Standalone architecture companion page.
out/investigation.json	Generated machine-readable Incident IR for audit and integration.
out/incident_report.html	Generated self-contained offline report and UI fallback.
siem_investigator/__init__.py	Package identity, version and top-level design statement.
siem_investigator/__main__.py	Allows python -m siem_investigator to invoke cli.main().
siem_investigator/schema.py	Canonical source vocabulary, required fields, dataset labels, dynamic ID patterns and schema health checks.
siem_investigator/ingest.py	Loads JSON, normalizes metadata/events, preserves original_event and creates EventStore.
siem_investigator/model.py	Defines Event, Finding, EventStore, Incident and confidence/severity constants.
siem_investigator/detectors.py	All deterministic behavior detectors, helper functions, detector registry and benign-review logic.
siem_investigator/correlate.py	Finding order/IDs, statistics, attack-path edges and technique grouping.
siem_investigator/attack.py	Offline ATT&CK; catalogue loading and optional live STIX reconciliation.
siem_investigator/blast_radius.py	Host/account/cloud aggregation and coverage-gap derivation.
siem_investigator/synthesize.py	Ten question builders, deterministic intent routing, summary and response actions.
siem_investigator/llm.py	Optional Anthropic digest/narration, intent classification and citation verification.
siem_investigator/report.py	Terminal renderer and generated self-contained HTML report.
siem_investigator/pipeline.py	Single orchestration entry point wiring all analysis stages.
siem_investigator/cli.py	Commands, arguments, artifact writing, interactive mode, UI launch and doctor preflight.
siem_investigator/web.py	Loopback HTTP server, investigation API, evidence retrieval and safe question endpoint.
siem_investigator/ui/index.html	Semantic analyst workspace structure and accessible controls.
siem_investigator/ui/app.css	Responsive visual system for launch, timeline, ATT&CK;, scope, response, Q&A; and drawer.
siem_investigator/ui/app.js	Calls the local APIs, renders the Incident IR and manages evidence/Q&A; interactions.
tests/test_ingest.py	Ingest count, source coverage, entity resolution, sorting, indexing and malformed-row behavior.

File	What it means and how it is used
tests/test_detectors.py	Attack phases, traceability, multi-source lateral movement, precision, confidence and C2 regularity.
tests/test_pipeline.py	End-to-end Incident construction, ten questions, summary format, routing and citation verification.
tests/test_schema.py	Schema mismatch warnings, data-driven names/IDs and non-hardcoded exfiltration logic.
tests/test_attack.py	Catalogue completeness and live reconciliation comparison behavior.
tests/test_supplied_dataset.py	Exact Meridian count, path, scope, key evidence, safe language and source preservation.
tests/test_web_ui.py	Local UI assets, preflight API, live investigation, evidence, Q&A; and guard behavior.

schema.py

Centralizes assumptions so field/source changes are visible in one place. validate_schema() checks missing sources and detector fields; unresolved_entity_rate() spots degraded host/IP correlation; event_id_pattern() adapts citation verification to the actual ID scheme.

ingest.py

_normalise_row() adds aliases and original_event. load_doc() parses timestamps, skips malformed records, creates Events and records source/window statistics. This stage is intentionally forgiving about optional fields and strict about citation-critical envelope fields.

model.py

Event is immutable evidence; Finding is the atomic conclusion; EventStore is the indexed corpus; Incident is the top-level IR. Serialization happens through to_dict()/dumps(), ensuring interfaces receive plain, reviewable data.

detectors.py

Contains helpers for internal IPs, process basenames, PowerShell decoding and finding construction. DETECTORS defines execution order. run_all() collects findings; review_benign() records near-misses that were considered and rejected when the relevant pattern exists.

correlate.py

Assigns chronological IDs after detection so F-### references remain stable for a dataset. It computes counts/duration, extracts directional edges from finding.data and groups ATT&CK; techniques by tactic for display.

attack.py

Uses a local catalogue by default. The live path indexes MITRE STIX attack-pattern objects, reports missing/renamed/deprecated entries and refreshes names/URLs without allowing network failure to break the investigation.

blast_radius.py

Groups findings by entities, assigns roles from phases, retains evidence and technique references, and adds gaps from metadata, uncertain hosts and anti-forensic behavior.

synthesize.py

Each q_* function is a deterministic view over Incident. The router scores normalized query text against bounded intent keywords. Unknown questions receive an honest capability response rather than a fabricated answer.

llm.py

Creates a compact digest rather than sending raw logs, calls Anthropic only when configured, and verifies every model-cited ID. The deterministic system remains complete without this file's optional path.

report.py

Creates a terminal investigation and a self-contained HTML artifact. Evidence JSON is embedded only for cited events, enabling offline drill-down while limiting report size.

pipeline.py

Owns orchestration and data-health warnings. It is the only analysis entry point used by the CLI, tests, report and live UI.

cli.py

Parses run/ui/ask/questions/timeline/report/json/stats/doctor. doctor performs a presentation preflight. ui starts the loopback server. Artifact commands write stable files under out/.

web.py

Serves static assets with security headers, validates request sizes, stores the completed Incident in memory, exposes only loopback by default and returns evidence on demand.

UI files

index.html defines structure, app.css defines responsive layout, and app.js escapes rendered values, invokes APIs, creates cards/graphs and manages the evidence drawer. The browser never contains detection logic.

14. Verification and quality strategy

> *The test suite is not only checking that code runs. It protects the claims that make the investigation trustworthy.*

Current validation result

37 automated tests pass. The doctor preflight confirms 242 events, four sources, findings, valid evidence IDs, two attack-path hops and an exfiltration finding.

Key invariants

- Every finding evidence ID resolves to a real Event.
- Every used ATT&CK; ID exists in the local catalogue.
- All ten assignment questions produce grounded output.
- The executive summary contains exactly three sentences.
- The authoritative Meridian path and entities match expected evidence.
- The UI cannot answer or expose evidence before an investigation exists.
- Original source records survive normalization.

What should be added in production

- Large-scale precision/recall evaluation against labelled incidents.
- Load, latency and memory tests over millions of events.
- Browser automation for the full visual click path.
- Security tests for authentication, authorization and evidence isolation.
- Detector-version replay and regression baselines.
- Chaos tests for missing sources, partial exports and malformed vendor records.

15. Running and presenting the project

Start the UI before the call. Present from the browser, use evidence clicks to prove conclusions and keep the terminal only as a fallback or when the interviewer asks for engineering detail.

Commands

```
# Preflight
python -m pytest -q
python -m siem_investigator doctor

# Primary live UI
python -m siem_investigator ui

# Alternative port
python -m siem_investigator ui --port 8877

# CLI / artifacts / questions
python -m siem_investigator
python -m siem_investigator stats
python -m siem_investigator timeline
python -m siem_investigator questions
python -m siem_investigator json
```

Eight-minute walkthrough

Time	Action	Message
0:00-0:45	Frame the problem	Logs are fragmented; the need is correlation and defensible decisions.
0:45-1:30	Show architecture	Agentic stages, deterministic truth layer, optional AI boundary.
1:30-2:20	Click Run investigation	Real pipeline, not replayed dashboard data.
2:20-3:00	Executive overview	Immediate CISO answers and source/metric confidence.
3:00-4:45	Timeline and F-007	Click EVT-0231/0232/0233 and prove cross-source correlation.
4:45-5:30	Exfiltration	Open EVT-0238 and show explicit external ownership and size.
5:30-6:15	Blast radius/gaps	Scope affected entities and explain what cannot be proven.
6:15-7:00	Ask investigation	Grounded answers over Incident IR, with clickable evidence.
7:00-8:00	Trust/product close	Human approval, limitations and production roadmap.

16. Engineering tradeoffs and production roadmap

The prototype deliberately concentrates effort on evidence, correlation and communication. Production readiness requires additional integration, governance, security and evaluation work.

Deliberate scope cuts

- Batch JSON instead of streaming connectors.
- Curated ATT&CK; subset instead of the full graph.
- Observed host/IP pairs instead of enterprise CMDB integration.
- Local, single-user UI instead of hosted multi-tenant service.
- Bounded intent router instead of unrestricted forensic chat.
- Recommendations without automated containment.

Another day

- Add more natural timeline/time-question paraphrases to the router.
- Add browser interaction tests for every evidence and Q&A; path.
- Produce detector precision results against validation labels.
- Add explicit UI confidence explanations per finding.
- Create a one-command demo launcher and packaged environment.

Another week

- Add schema-registry-driven source adapters and streaming ingestion.
- Integrate CMDB, identity, email and threat intelligence.
- Add case management, analyst notes and approval workflow.
- Version detectors and support replay over historical incidents.
- Evaluate model-assisted hypotheses behind an evidence gate.
- Benchmark analyst time saved and answer accuracy.

Production controls

- SSO, RBAC, tenant isolation, encryption and secrets management.
- Immutable evidence storage and chain-of-custody logs.
- Source health monitoring, failure queues and replay.
- Metrics for precision, recall, latency and analyst override.
- Prompt/model evaluations and output policy for GenAI.
- SOAR actions only behind explicit human authorization.

17. Comprehensive interview question bank

Answers are intentionally concise, direct and conversational. Use the ideas rather than memorizing every sentence. Where a question needs depth, add the real event example shown in the handbook.

A. Problem, value and project framing

1. What problem are you solving?

- The problem is fragmented investigation evidence. Endpoint, identity, firewall and cloud tools each show only part of the attack. The project reduces the analyst's manual correlation work and produces one traceable timeline, blast radius and response brief for technical and executive users.

2. Why is normal SIEM search not enough?

- Search returns records that match a query, but it does not reliably explain how those records form one intrusion. This project adds entity resolution, time-based correlation, ATT&CK; context, confidence, uncertainty and evidence-linked synthesis. It turns rows into an investigation rather than another alert list.

3. Who is the primary user?

- The strongest user today is a Tier 2 or Tier 3 SOC analyst who needs to accelerate triage and investigation. Incident commanders and CISOs benefit from the same structured record through different views. It is decision support, not a replacement for an experienced investigator.

4. What is the tangible artifact?

- The main artifact is a live local investigation workspace launched with one command. It runs the real pipeline, then exposes an executive overview, timeline, ATT&CK; matrix, blast radius, response actions, coverage gaps, grounded questions and clickable original evidence. An offline HTML report is the fallback.

5. What makes this different from a dashboard?

- A dashboard displays metrics. This system executes an investigation workflow and preserves the reasoning chain from event to finding to executive claim. The strongest demonstration is opening F-007 and showing how three records from two sources jointly prove PsExec lateral movement.

6. How does this save analyst time?

- It removes repetitive steps: schema interpretation, timestamp ordering, host/IP resolution, ATT&CK; lookup, evidence packaging and audience-specific reporting. The analyst starts from a reconstructed hypothesis with citations, reviews the key evidence and focuses time on validation, containment and unresolved gaps.

7. How would you measure business value?

- I would measure time to first defensible timeline, time to containment decision, percentage of findings accepted by analysts, false-positive rate, evidence-click usage, repeated-question consistency and analyst override rate. The goal is faster correct decisions, not simply more generated findings.

8. Why is trust especially important here?

- An unsupported security conclusion can isolate the wrong server, disable a critical account or trigger incorrect legal reporting. The system therefore treats traceability as a product requirement: deterministic findings, explicit confidence, preserved originals, coverage gaps and human approval before any response action.

B. Architecture and agentic design

9. Explain the architecture in one minute.

- The pipeline ingests and normalizes four SIEM sources, creates indexed events, runs deterministic behavior detectors, correlates findings by entity and time, enriches them with ATT&CK;, calculates blast radius and gaps, and packages one Incident IR. CLI, JSON, report, UI and optional narration all read that IR.

10. Why did you split the workflow into stages?

- Each stage has one bounded responsibility and a testable input/output contract. That makes schema changes, detector changes and presentation changes independent. It also creates verification points, which is important in security because a silent error in ingestion should not look like a clean investigation.

11. Why do you call it agentic if most stages are deterministic?

- Agentic design means decomposing a goal into specialized, tool-using steps that share structured state and verify progress. It does not mean every step needs a language model. In a high-consequence forensic workflow, deterministic tools are the right agents for evidence and judgment.

12. What is the Incident IR?

- It is the structured source of truth produced by the pipeline. It contains findings, timeline, attack path, affected hosts/accounts/cloud resources, ATT&CK; metadata, statistics, evidence references and coverage gaps. Every presentation surface reads it, so the UI and reports cannot invent separate versions of the incident.

13. Why use one pipeline entry point?

- pipeline.run() guarantees that tests, CLI, UI and generated artifacts use identical forensic logic. Without that boundary, a convenient UI transformation could slowly become a second investigation engine. A single entry point makes changes reviewable and keeps outputs consistent.

14. What state moves between stages?

- Events move from ingestion into EventStore. Detectors emit Finding objects with evidence and entities. Correlation adds chronological IDs, statistics and directional edges. ATT&CK; and blast-radius stages add standardized context and scope. The final Incident carries all of that state into synthesis and presentation.

15. Where is verification performed?

- Verification happens at multiple boundaries: ingestion records malformed rows, schema checks report missing sources and fields, evidence IDs must resolve, ATT&CK; IDs must exist, question answers are tested for grounding, optional model citations are checked and doctor verifies the complete presentation path.

16. Could the UI work without the CLI?

- Yes. The UI calls the same Python pipeline through a loopback HTTP API. The CLI is still valuable for automation, debugging and fallback. Neither is the source of truth; the Incident object is. That separation is why both interfaces can coexist without duplicating forensic logic.

C. Data, schemas and normalization

17. What exactly is the input?

- The input is a 242-event synthetic SIEM export spanning endpoint, authentication, network and cloud-storage sources. It also includes incident metadata, collection window and source descriptions. Events are shuffled, so the system cannot rely on file order to reconstruct the attack.

18. Why is normalization necessary?

- Each source uses different names for common concepts. Endpoint has hostname and process_name; authentication has source_host and dest_host; cloud has source_ip and file_size_bytes. Normalization gives detectors one vocabulary while retaining every original field for evidence review.

19. Does normalization change the evidence?

- It adds canonical aliases but does not replace the original object. The exact supplied record is stored under original_event. In the UI, an analyst can compare Original event with Normalized view. That makes the adapter transparent and prevents a convenience transformation from hiding source evidence.

20. Give a normalization example.

- EVT-0228 originally uses user_logon, username, source_host, dest_host and source_ip. The canonical view uses logon_success, user, src_host, host and src_ip, with network logon converted to type 3. The original record is still preserved beside those aliases.

21. How do you handle malformed rows?

- Citation-critical fields are strict: an event needs an ID, timestamp and source identity. Invalid timestamps or missing envelope fields are skipped and counted. Optional fields are tolerated because real exports are messy. The system reports ingest statistics rather than creating partially valid phantom evidence.

22. How do you detect schema drift?

- schema.validate_schema() checks whether all expected sources exist and whether any source never provides fields used by its detectors. The pipeline also warns when no findings are produced or internal IPs cannot resolve to hosts. The goal is to fail loudly instead of silently degrading.

23. How is time handled?

- All timestamps are parsed into timezone-aware UTC datetimes and events are sorted chronologically in EventStore. Findings use representative UTC timestamps, normally their earliest evidence. This avoids local-time ambiguity and allows detector windows and the 11.9-hour incident duration to be computed consistently.

24. What is entity resolution here?

- EventStore learns host/IP pairs from observed src_host and src_ip fields. That lets a firewall IP be connected to an endpoint hostname. In production I would supplement this with CMDB and identity sources because observed mappings alone can be incomplete or stale.

25. Are the ATTACK notes used?

- No. They are validation annotations supplied with the synthetic dataset. Detectors ignore the note field and use process lineage, commands, logons, IPs, ports, service creation, timestamps, file sizes and bucket ownership. Reading the notes would be label lookup, not investigation.

26. Why keep the raw file in the repository?

- It makes the assignment reproducible and lets an interviewer run the exact same investigation. In production, raw evidence would normally live in controlled immutable storage rather than source control, with the application receiving authorized references or streams.

D. Detection and incident-specific evidence

27. How did you identify initial access?

- EVT-0221 shows WINWORD.EXE spawning cmd.exe, and EVT-0222 shows encoded PowerShell immediately afterward. That process lineage is strongly consistent with malicious document execution. I call the on-host execution confirmed, while keeping the phishing email itself inferred because email logs are absent.

28. Why is the phishing email not fully confirmed?

- The endpoint proves that Word launched a command shell, but it does not contain the message sender, attachment name or delivery path. Without email telemetry I cannot inspect the message itself. The system therefore states the limitation instead of upgrading process evidence into a fabricated email claim.

29. How is encoded PowerShell detected?

- The detector first checks that the process is PowerShell or pwsh, then looks for encoded-command or stealth flags such as -enc and hidden-window behavior. It may attempt a best-effort decode, but it never invents decoded content when the payload is incomplete.

30. How is C2 beaconing detected?

- Allowed internal-to-external flows are grouped by source and destination. The detector calculates consecutive time gaps and their coefficient of variation. EVT-0223 through EVT-0225 are roughly 15.5 minutes apart with about one percent jitter, which supports automated HTTPS callbacks rather than normal browsing.

31. Could three connections be a false positive?

- Yes, three events are a modest sample, so production thresholds would depend on asset role, destination reputation and baseline behavior. In this dataset, the periodicity follows malicious process execution and uses one external IP. I would keep the evidence visible and tune the rule with labelled data.

32. How is LSASS credential access detected?

- EVT-0226 is a process_access event targeting lsass.exe with high-risk access rights. EVT-0227 creates a sizeable temporary file twelve seconds later. The detector joins those endpoint artifacts and the later account pivot strengthens the interpretation that credentials were harvested.

33. How do you know the jdavis credentials were used?

- After LSASS access on WKSTN-07 in the jdavis context, EVT-0228 records a successful network logon by jdavis from that workstation to AUTH-SRV-01. The same source, account and close time connect credential access to the first internal pivot.

34. What is WKSTN-07?

- It is the employee workstation where the initial process execution, HTTPS callbacks and LSASS access occurred. It is treated as the initial foothold. Its address 10.0.2.47 later appears as the source of the jdavis authentication to AUTH-SRV-01.

35. What is AUTH-SRV-01?

- It is the authentication server reached with the jdavis network logon. The attacker then enumerated domain groups and users there. I describe it as the first internal pivot; I do not automatically call it a domain controller because the supplied evidence does not establish that role.

36. What is FILE-SRV-02?

- It is the second pivot and the sensitive data source. AUTH-SRV-01 reached it over SMB, PSEXESVC created a SYSTEM shell, finance data was archived there, and the resulting 2.3 GiB file was uploaded to external cloud storage before cleanup.

37. Why is F-007 the strongest finding?

- It fuses three records from two telemetry sources: SMB from AUTH-SRV-01, PSEXESVC creation on FILE-SRV-02 and a SYSTEM cmd.exe launched by PSEXESVC. The sequence occurs within 34 seconds and independently proves transfer, remote execution and shell creation.

38. How was data collection detected?

- EVT-0236 shows 7z.exe archiving the finance-data network share. EVT-0237 records backup_archive.zip at 2,473,829,122 bytes, or about 2.3 GiB. The known archiver, sensitive share, output artifact and timing create a direct collection/staging finding.

39. Why is exfiltration confirmed?

- EVT-0238 is a direct cloud audit record. It names backup_archive.zip, FILE-SRV-02, jdavis, the file size, destination ext-drop-xf9q2, action allowed and bucket_owner EXTERNAL. Unlike an outbound-byte anomaly, it explicitly records a completed upload to an external destination.

40. How do you detect cleanup?

- Endpoint records show backup_archive.zip deleted, 7z.exe deleted and the PSEXESVC service removed after the upload. Those are mapped to indicator removal. The timing matters because deletion after collection and exfiltration is more meaningful than an isolated temporary-file cleanup.

41. Did the attacker compromise a domain controller?

- The evidence does not establish a domain-controller compromise. AUTH-SRV-01 is an authentication server and confirmed pivot, but the dataset does not identify it as a DC or show a domain-admin session on one. The response advice explicitly avoids an unjustified KRBTGT reset.

42. Was PHI stolen?

- The evidence identifies a finance-data share and archive. It does not establish that the contents are PHI. The system therefore reports confirmed exfiltration of the observed archive and asks legal/privacy/data owners to determine sensitivity rather than making an unsupported healthcare-data claim.

E. Correlation, confidence, ATT&CK; and blast radius

43. Are you just checking whether logs are the same?

- No. Related events are normally different. Correlation asks whether their entities, timestamps and behaviors fit one sequence. An SMB flow, service creation and SYSTEM shell are not equal records; together they describe PsExec lateral movement from the source server to the destination.

44. What dimensions do you correlate on?

- The main dimensions are UTC time, source and destination host/IP, account, port/protocol, target process, parent process, service name, file path, filename, size and cloud ownership. Individual detectors use only the dimensions relevant to that behavior.

45. How are correlation windows chosen?

- They are behavior-specific engineering assumptions. PsExec service/shell evidence must appear within minutes of SMB; the valid-account pivot looks within four hours of credential access. In production, I would version and tune these windows using labelled incidents and environment baselines.

46. How do you reconstruct the timeline?

- Each Finding receives a representative timestamp, usually the earliest supporting event. Findings are sorted and assigned stable F-### IDs. The current sequence begins at 08:12:33 UTC and ends with service cleanup at 20:05:38 UTC, an observed duration of 11.9 hours.

47. How do you construct the attack path?

- Lateral-movement findings carry structured src_host, dst_host and edge fields. correlate.attack_path() orders unique edges by finding time. The result is WKSTN-07 to AUTH-SRV-01 via valid account, then AUTH-SRV-01 to FILE-SRV-02 via SMB/PsExec.

48. What does CONFIRMED mean?

- It means either multiple independent sources corroborate the behavior or one source contains a direct, unambiguous audit fact. PsExec is multi-source confirmed; the external upload is directly confirmed by cloud audit. It does not mean every possible action on the host is known.

49. What is SUSPECTED?

- It is a meaningful signal that fits the attack but lacks enough corroboration. For example, encoded PowerShell without related network, process or file evidence might remain suspected. The state tells the analyst to investigate further rather than treating the signal as proven compromise.

50. What is UNCERTAIN?

- It represents access or indirect evidence where missing telemetry prevents understanding what happened next. A successful logon to a server with no endpoint agent is a typical example. Keeping it uncertain avoids both false reassurance and unsupported certainty.

51. Why are all current findings confirmed?

- The embedded Meridian behaviors have either direct audit records or strong supporting evidence. That does not imply perfect visibility. The system still reports missing email, DNS and proxy telemetry, and those gaps constrain what can be said about delivery, domains, URLs and unlogged channels.

52. Does no finding mean the host is clean?

- No. It means the available data and implemented rules did not establish a finding. The host might be clean, the activity might be novel or the required source might be missing. Production conclusions need source-health checks, broader detection coverage and analyst review.

53. What does MITRE ATT&CK; add?

- It provides a standard vocabulary for established behaviors, including technique IDs, names, tactics and official links. That improves analyst communication and coverage views. ATT&CK; does not make the compromise decision; the detector and evidence do that first.

54. Why not download the full ATT&CK; feed every run?

- A live dependency makes incident response and interviews less reliable. The project ships a small verified subset for the techniques it uses, so it works offline. A separate refresh option checks IDs, names, URLs and deprecated status against the authoritative STIX feed.

55. How do you calculate host blast radius?

- Every finding lists its hosts. Findings are grouped per host, then the output records strongest confidence, attack role, related findings, techniques, first-seen time and evidence. That yields WKSTN-07, AUTH-SRV-01 and FILE-SRV-02 for this incident.

56. How do you calculate account blast radius?

- The same aggregation is applied to finding accounts. jdavis appears in initial execution context, credential access, the network pivot, PsExec activity, archive creation and upload. Its role is described from those phases rather than from a hardcoded compromised-account list.

57. How is cloud scope determined?

- Cloud evidence is inspected for source and destination resources. EVT-0238 marks ext-drop-xf9q2 as an externally owned destination, so it becomes a confirmed cloud resource in the blast radius. The system does not invent a source bucket when the record describes a direct upload.

F. UI, question answering and GenAI

58. How does the UI execute the investigation?

- The Run investigation button sends POST /api/investigate to the local Python server. That endpoint calls pipeline.run(), converts the returned Incident into presentation JSON and sends it back. JavaScript renders the views but performs no detection or confidence logic.

59. Why use a local UI?

- It is reliable for an interview, requires no deployment, keeps evidence on the machine and adds no web-framework dependency. It also demonstrates product thinking without distracting from the forensic engine. Production would add authenticated hosting, tenant isolation and controlled evidence storage.

60. What happens when I click an evidence ID?

- The browser requests /api/evidence/. The server retrieves that Event from EventStore and returns both the exact original_event and the normalized view. The drawer makes the evidence and transformation inspectable without sending every raw record to the browser upfront.

61. Are the questions hardcoded?

- The supported intents are deliberately bounded around the ten assignment questions, but the answers are generated from the current Incident IR. A deterministic keyword router handles known paraphrases. I would describe this as constrained intent-based Q&A;, not hardcoded answers or unrestricted chat.

62. Why did the time-question paraphrase fail?

- The investigation contained the timestamps, but the keyword router did not classify that wording into the timeline intent. That is a routing limitation, not an evidence failure. I would add the paraphrase to tests or use the optional model only for intent classification.

63. Where exactly is GenAI used?

- It is optional. The model can classify a free-form query into one supported intent and can narrate an already-built Incident digest. Detection, evidence selection, correlation, confidence, ATT&CK; mapping and containment decisions stay deterministic and work without an API key.

64. Why not send all raw logs to an LLM?

- It would increase cost, privacy exposure, context pressure and nondeterminism while weakening reproducibility. The system first reduces logs into a structured, cited Incident IR. A model can communicate that smaller trusted record, but it should not establish forensic truth from thousands of raw rows.

65. How do you prevent model hallucination?

- The model cannot create Findings. Its input is a compact Incident digest, it is instructed to preserve confidence and cite only known IDs, and a verification pass marks citations outside the valid event/finding set. Human review still matters because valid citations can be misinterpreted.

66. Can the UI take containment actions?

- No. It displays evidence-conditioned next-two-hour recommendations and a human-approval banner. Isolation, account disablement and blocking are high-impact actions that require authorization, business context and operational coordination. A future SOAR integration would still require explicit approval gates.

67. What if the local UI fails?

- The generated incident_report.html is a self-contained offline fallback, and the CLI can print the same timeline, statistics and grounded answers. All surfaces use the same Incident IR, so falling back does not change the forensic conclusions.

G. Trust, testing and engineering judgment

68. What is your strongest anti-hallucination control?

- The strongest control is structural: Findings are created by deterministic code and must carry real evidence IDs. The model is downstream of that boundary. Citation verification helps, but the more important choice is preventing a language model from creating the forensic record in the first place.

69. How do you prove traceability?

- Every Finding stores its evidence list, tests assert that every ID resolves in EventStore, reports make IDs clickable and the UI retrieves the original record on demand. The chain is visible from executive sentence to Finding to event rather than hidden in model reasoning.

70. What does doctor check?

- It verifies that events were ingested, all four source types are present, findings exist, every finding cites valid event IDs, an attack path was reconstructed and exfiltration evidence was identified. It returns nonzero on a blocking failure and is designed for pre-demo confidence.

71. What do the tests cover?

- The 37 tests cover ingestion, malformed events, sorting, entity resolution, detector phases, evidence integrity, confidence vocabulary, ATT&CK; catalogue consistency, schema drift, dataset-specific path/scope, safe response language, question routing, model citation checks and live UI/API behavior.

72. What do the tests not prove?

- They do not prove production detector precision, browser visual quality across every device, performance at enterprise scale or safety under hostile multi-tenant input. Those require labelled evaluation sets, load testing, browser automation, security testing and operational pilots.

73. What was your main engineering tradeoff?

- I prioritized a trustworthy vertical slice over breadth: one supplied dataset, clear detectors, one Incident IR and multiple presentation views. I avoided streaming infrastructure, full ATT&CK; ingestion, unrestricted chat and autonomous actions because they would add risk without improving the core demonstration.

74. What would you change with another day?

- I would improve paraphrase coverage, add automated browser click-path tests, display confidence explanations more explicitly, evaluate detectors against the dataset labels and package the demo into one launcher. Those changes improve usability and proof without changing the architecture.

75. What would you change with another week?

- I would add pluggable source adapters, CMDB and identity integration, analyst notes and approvals, detector versioning, historical replay, labelled evaluation and model-assisted hypothesis generation behind a strict evidence gate. I would also measure time saved in analyst trials.

76. Where can the system still fail?

- Rules can miss novel behavior or flag legitimate administration. Missing logs can hide actions. Entity data can be stale. ATT&CK; can drift. An LLM can misstate cited evidence. The design surfaces these risks, but production still needs monitoring, evaluation, feedback and human review.

77. How would you scale beyond 242 events?

- I would replace in-memory scans with indexed storage and streaming windows, partition by tenant/time/source, precompute entity mappings, use event-time watermarks and run detectors incrementally. The Finding and Incident contracts can stay stable while the execution engine becomes distributed.

78. How would you support another SIEM vendor?

- I would add a source adapter that maps the vendor schema into the canonical Event vocabulary, declare its required/optional fields and run contract tests. Detectors should not change unless the new source introduces genuinely new semantics rather than renamed fields.

79. How would you secure a production deployment?

- I would add SSO, RBAC, tenant isolation, encryption, secrets management, evidence-level authorization, immutable audit logs, secure headers, rate limits and incident retention policies. Model calls would use approved regions and minimized digests, with no raw evidence sent by default.

80. Why is standard-library-only useful?

- It reduces setup and demo risk and keeps the forensic path available without package installation or network access. That is appropriate for a prototype. In production I would accept well-governed dependencies for APIs, persistence, authentication and observability where they provide clear value.

81. How did AI assist development?

- AI accelerated schema review, implementation, test generation, documentation and adversarial checks. I still validated behavior against the supplied events, ran tests and kept final security judgments deterministic. That demonstrates responsible AI-assisted engineering rather than delegating incident truth to generated code or prose.

H. Product and production thinking

82. What user problem does the UI solve?

- It reduces context switching. The analyst sees the board summary, attack path, timeline, evidence, ATT&CK;, scope, gaps and actions in one place. Evidence remains one click away, so the interface supports fast review without asking the user to trust a black-box conclusion.

83. Would a CISO use the same screen as an analyst?

- They can share the same incident record but emphasize different views. A CISO starts with summary, scope, impact and decisions. An analyst spends more time in timeline, evidence and gaps. The prototype demonstrates both; production could add role-specific layouts.

84. What would make this production-ready?

- Reliable connectors, schema registry, CMDB/identity integration, durable event and case storage, RBAC, SSO, audit logging, detector versioning, labelled evaluation, observability, analyst feedback, workflow approvals, privacy controls and a supported deployment model. The prototype proves direction, not operational completeness.

85. Would you automate containment later?

- Only selected low-risk actions and only with policy and approval. The system could prepare SOAR actions, show predicted impact and gather approvers. Isolating clinical or identity infrastructure can be disruptive, so evidence quality alone is not enough; business context and authorization remain necessary.

86. How would analysts provide feedback?

- Each finding should support accept, reject, needs-more-evidence and comment states. Feedback would be stored with detector version and evidence context, then used for tuning and evaluation. I would not silently train on every click; governance and label quality matter.

87. How would you handle multiple simultaneous incidents?

- I would cluster findings by shared entities, indicators and time, while allowing analysts to merge or split cases. The current single Incident model would become a case-level object referenced by findings. Correlation must avoid linking unrelated activity merely because one service account is common.

88. How would legal or compliance use the output?

- They need a defensible chronology, affected systems/data, evidence references, confidence and explicit unknowns. The structured JSON and clickable report provide a starting package, but legal conclusions and notification decisions still require counsel, data classification and chain-of-custody controls.

89. What is the product's biggest current limitation?

- Detection breadth. It reconstructs the supplied behaviors well, but it is not a general enterprise detection platform. The right next step is not more polished UI; it is evaluated content coverage, source adapters and analyst feedback across varied labelled incidents.

I. Live demonstration questions

90. What should you show first in the interview?

- Start with the operational problem and the UI launch screen, then show the architecture briefly. Click Run investigation, lead with the executive overview and prove one difficult finding with raw evidence. Do not begin by reading source code or terminal output.

91. Which finding should you emphasize?

- Use F-007. It directly addresses the brief's warning about missed lateral movement and demonstrates the project's real value: cross-source correlation. Open EVT-0231, EVT-0232 and EVT-0233 and explain how network and endpoint records independently support one conclusion.

92. Which evidence proves exfiltration?

- Open EVT-0238. Point to FILE-SRV-02, jdavis, backup_archive.zip, 2,473,829,122 bytes, action allowed, ext-drop-xf9q2 and bucket_owner EXTERNAL. This is stronger than an inference from outbound bytes because the cloud audit record describes the completed upload.

93. What uncertainty should you mention?

- Mention that email, DNS and proxy sources are absent. Therefore the malicious process lineage is direct but the delivery message is inferred, and the C2 IP is known without its domain or URL. Honest limits improve credibility; they do not weaken the investigation.

94. What if a question is not recognized?

- Be direct: the current prototype has bounded intents, and that wording was not routed. Explain that the Incident contains the evidence and the limitation is question classification. Then select the closest suggested question or show the timeline. Do not pretend the fallback is a security conclusion.

95. How should you close the demo?

- Finish with the trust boundary and product roadmap: deterministic evidence, optional AI communication, human-approved response and clear production requirements. The closing message is that the project accelerates defensible decisions, not that AI replaces investigators.

18. Final quick reference

Use this page immediately before the interview. It summarizes the language, numbers and evidence that matter most.

Numbers to remember

Metric	Value
Events	242
Sources	4
Findings	12
Techniques	14
Tactics	9
Hosts	3
Accounts	1
Pivots	2
Duration	11.9 hours
Exfiltration	2.3 GiB confirmed

Evidence to remember

Evidence	Meaning
EVT-0221/0222	Word -> cmd -> encoded PowerShell
EVT-0223-0225	Periodic HTTPS callbacks
EVT-0226/0227	LSASS access and dump artifact
EVT-0228	jdavis pivot to AUTH-SRV-01
EVT-0231-0233	SMB + PSEXESVC + SYSTEM shell
EVT-0236/0237	Finance archive creation
EVT-0238	Confirmed external upload
EVT-0239-0241	Cleanup and indicator removal

Language to use

- Say compromised, not corrupted.
- Say constrained intent-based Q&A;, not hardcoded answers.
- Say ATT&CK; enriches established findings; it does not detect compromise.
- Say the phishing delivery is inferred while on-host execution is observed.
- Say decision support with human approval, not autonomous containment.
- Say no finding is not proof of no compromise.

CLOSING STATEMENT

Defensible decisions, not automated certainty.

I designed an agentic investigation workflow that is fast enough for incident pressure, structured enough for engineering, traceable enough for executive and legal scrutiny, and honest enough to state what the evidence cannot prove.

Sahaj Bhadja